Analisi del rapporto sull'incidente

Riepilogo	La rete interna dell'azienda ha smesso di rispondere per un po' e nessuno poteva usare i servizi di rete. Il team di sicurezza ha scoperto che la causa era un'ondata di pacchetti ICMP arrivati dall'esterno, cioè un attacco distribuito di negazione del servizio (DDoS). Per tornare al lavoro, il team ha bloccato il traffico ICMP in ingresso e ha fermato i servizi non critici, così da ripristinare prima quelli critici. Identificare, Proteggere e Rilevare descrivono ciò che l'azienda cambia dopo questo incidente per essere più preparata. Rispondere e Ripristinare descrivono come si gestisce l'incidente vero e proprio.
Governare	Queste decisioni devono avere un responsabile prima del prossimo attacco. Metterei per iscritto chi può autorizzare il blocco del traffico o lo spegnimento dei servizi non critici, e quali servizi sono critici, così il team non deve discuterne nel mezzo di un blocco. La direzione dovrebbe anche rivedere a scadenze fisse le regole del firewall e dell'ICMP, non solo quando qualcosa si rompe.
Identificare	L'azienda è stata colpita da un ICMP flood. Il punto debole era un firewall che non limitava i pacchetti ICMP in ingresso, così l'attaccante ha potuto sovraccaricare l'intera rete interna. Tutto ciò che dipende dalla rete è stato colpito, quindi le risorse critiche vanno individuate in anticipo e protette per prime.
Proteggere	Una nuova regola del firewall ora limita la velocità con cui i pacchetti ICMP possono entrare nella rete. Il team ha anche aggiunto un IDS/IPS che filtra il traffico ICMP con caratteristiche sospette.
Rilevare	Il firewall ora controlla l'indirizzo IP di origine dei pacchetti ICMP in ingresso per scoprire indirizzi falsificati. È stato aggiunto anche un software di monitoraggio di rete per individuare presto schemi di traffico anomali.
Rispondere	La prossima volta isoleremo per prima cosa i sistemi colpiti, così il problema non si estende. Poi ripristineremo i sistemi e i servizi critici, leggeremo i log di rete cercando qualcosa di strano e segnaleremo l'incidente alla direzione e, quando la legge lo richiede, alle autorità.
Ripristinare	Per riprendersi da un ICMP flood si blocca il traffico ICMP esterno sul firewall e si fermano i servizi non critici per ridurre il carico dentro la rete. I servizi critici tornano per primi. Quando

	l'ondata è esaurita, si possono ripristinare anche gli altri servizi.
Riflessioni / Note	Una regola del firewall e uno strumento di monitoraggio avrebbero potuto evitare all'azienda un lungo blocco. Ho anche imparato che la risposta ha bisogno di un ordine: bloccare il traffico, ridurre il carico, rimettere in funzione ciò che è critico, poi il resto. Quello che ho imparato qui rientra in ogni funzione sopra, a partire da Governare.